API conventions

English version of ../../api/conventions.md.

Rules

Rule	Detail
Format	JSON for `/api/*`, HTML templates for pages
Liveness	`GET /health` — process state and both databases
Realtime	Socket.IO (`app/realtime/socket_events.py`), room and chat events
Authentication	Flask session plus `SECRET_KEY`; admin functions require `ADMIN_SECRET_KEY`
Validation	`app/validation.py` — a single entry check
Errors	`app/errors.py` — one error response format
CORS	`CORS_ORIGINS`, `*` by default — **narrow it in production**
Cookies	`SESSION_COOKIE_SECURE=true` over HTTPS

Route groups

`/api/rooms`, `/api/leaderboard`, `/api/profile`, `/api/campaign`, `/api/learn`, `/api/ugc`, `/api/admin`, `/api/cheat` (closed by `CHEAT_TESTER_CODE`). The exact list lives in `app/http_api/*.py`; the README describes the game scenarios.

Response safety

- Private keys and codes never appear in responses (checked by `tests/test_security.py`).
- Admin routes require a separate secret, not just a session.
- Errors contain no tracebacks when `DEBUG=false`.

How to change the API

1. Change the route and validation. 2. Update `static/js/*` (the client). 3. Run `make lint test`. 4. Add a row to verification/matrix.md when a new claim appears.